

ReFineID – déclaration d'un moyen de cryptologie

Dossier de déclaration au titre de l'article 30 de la loi n° 2004-575 du 21 juin 2004 pour la confiance dans l'économie numérique (LCEN) et du décret n° 2007-663 du 2 mai 2007 pris pour son application.

La déclaration est faite au titre du chapitre II, sans préjudice de l'application du II de l'article 30, qui affranchit de toute formalité les moyens assurant exclusivement des fonctions d'authentification ou de contrôle d'intégrité. Le déclarant ne préjuge pas de cette qualification et prie l'ANSSI de bien vouloir lui indiquer si elle s'applique au moyen décrit ci-après.

Le présent document constitue la déclaration. Il est établi selon l'annexe I de l'ANSSI, dont il reprend les rubriques A à F dans le même ordre, sous leurs intitulés ou leur équivalent : chaque question y trouve sa réponse, à sa place.

Nature de la demande : **déclaration de fourniture et de transfert depuis un État membre de l'Union européenne** d'un moyen de cryptologie, au titre du seul chapitre II du décret n° 2007-663.

Le déclarant est établi en Finlande et le moyen est distribué depuis l'Union européenne, notamment par l'App Store d'Apple. Les opérations déclarées sont donc la fourniture du moyen en France et son transfert depuis un État membre. Le transfert vers un État membre depuis la France et l'exportation depuis la France vers un État tiers, que le IV de l'article 30 soumet à autorisation, ne sont pas le fait du déclarant et ne font pas l'objet de la présente déclaration.

Aucune demande d'autorisation au titre du chapitre III n'est formée.

Le dossier est établi en français et suivi d'une version anglaise.

A. Déclarant et/ou demandeur

Le déclarant est un particulier. ReFineID est un nom commercial qu'il emploie en son nom propre ; il ne désigne aucune personne morale. Il n'y a ni dénomination sociale, ni numéro SIRET, ni société pour le compte de laquelle la déclaration serait faite.

Champ	Valeur
Nom et prénoms	Koistinen, Petri
Nationalité	finlandaise
Adresse	Niittaajankatu 8a A 21, 00810 Helsinki, Finlande
Numéro de téléphone	+358 44 956 4098
Adresse de courrier électronique	petri.koistinen@iki.fi

Personne que l'ANSSI peut contacter pour obtenir des informations techniques sur le moyen : la même, aux mêmes coordonnées.

Le déclarant est également le fabricant du moyen ; la rubrique relative à un fabricant tiers est sans objet.

B. Moyen de cryptologie auquel s'appliquent la déclaration et/ou la demande d'autorisation

B.1. Informations générales sur le moyen

Champ	Valeur
Dénomination du moyen	ReFineID
Désignation générique	Intergiciel pour carte nationale d'identité
Marque de distribution	ReFineID
Référence commerciale	ReFineID pour plateformes Apple (application App Store, identifiant de lot <code>fi.refineid.ReFineID</code>)
Version	Versionnement calendaire AA.M.J (26.8.3 à la date du dossier)
Date de mise sur le marché	1er novembre 2026
Plateformes	iOS 26, iPadOS 26, macOS 26

B.2. Description fonctionnelle du moyen

B.2.1. Classez le moyen dans la ou les catégorie(s) correspondante(s)

Logiciel. Le moyen ne comporte aucun élément matériel.

B.2.2. Description générale du moyen

ReFineID rend la carte nationale d'identité finlandaise utilisable comme identité numérique fondée sur un certificat client, au moyen des infrastructures de sécurité d'Apple. Le moyen lit la carte via l'antenne NFC du téléphone ou un lecteur de carte à contact, publie le certificat d'authentification et la clé publique de la carte dans le trousseau du système par CryptoTokenKit, et transmet les demandes de signature à la carte. Safari et les autres applications du système s'authentifient ensuite avec la carte comme avec tout autre certificat client. Le porteur s'en sert pour se connecter à des services en ligne avec sa carte d'identité.

La présente déclaration porte sur cette seule application pour plateformes Apple, distribuée par l'App Store. Un intergiciel ReFineID pour postes de travail, distribué séparément et dont les fonctions cryptographiques diffèrent, n'entre pas dans son champ.

B.2.3. Indiquez à quelle catégorie se rapporte la fonction principale du moyen

Sécurité de l'information (bibliothèque et intergiciel cryptographiques). Aucune des autres catégories proposées – ordinateur, envoi/stockage/réception d'informations, réseau – ne s'applique.

B.3. Description technique des services de cryptologie fournis

B.3.1. Description des fonctionnalités cryptographiques du moyen

Deux fonctions, et aucune autre :

1. **Établissement d'un canal sécurisé avec la carte.** La carte bloque l'accès à son application PKCS#15 sur l'interface sans contact et refuse toute lecture tant que PACE n'a pas été exécuté. PACE est un accord de clés authentifié par mot de passe, fondé sur le numéro

d'accès imprimé sur la carte. Il établit la preuve de la connaissance du numéro d'accès et dérive des clés de session; tous les échanges ultérieurs avec la carte sont chiffrés et authentifiés au moyen de ces clés.

2. **Signatures d'authentification client.** La clé privée reste dans la carte, qui réalise la signature. Le moyen met en forme l'entrée, la transmet à la carte, et vérifie le résultat avec la clé publique de la carte avant de le restituer au système d'exploitation.

Le chiffrement est confiné à ce canal et à la seule interface sans contact. Il n'est pas offert au porteur : il est imposé par la politique d'accès de la carte. Sur l'interface à contact, le moyen ne chiffre rien. La clé publiée au système d'exploitation est réservée à la signature : le moyen n'offre à ses appelants ni déchiffrement ni accord de clés.

Le moyen ne chiffre pas les données de l'utilisateur au repos, ne chiffre ni fichiers ni supports de stockage, n'offre ni messagerie ni téléphonie chiffrées, ne met en œuvre aucun réseau privé virtuel (VPN) ni tunnel de transport, et n'établit par lui-même aucune communication réseau.

B.3.2. Indiquez à quelle(s) catégorie(s) se rapporte(nt) la ou les fonctions cryptographiques du moyen

Authentification, intégrité, confidentialité et signature – toutes quatre, exercées entre le moyen et la carte, et non sur les données de l'utilisateur.

B.3.3. Indiquez le(s) protocole(s) sécurisé(s) utilisés par le moyen

Ni IPsec, ni SSH, ni protocoles de VoIP, ni SSL/TLS. TLS est assuré par le système d'exploitation; le moyen ne met en œuvre aucune pile TLS et se borne à fournir la signature calculée par la carte.

Autres protocoles : PACE selon ICAO Doc 9303 partie 11 et BSI TR-03110-3, suite id-PACE-ECDH-GM-AES-CBC-CMAC-256 (OID 0.4.0.127.0.7.2.2.4.2.4); messagerie sécurisée selon ISO/IEC 7816-4.

B.3.4. Précisez les algorithmes cryptographiques utilisés et leurs longueurs maximales de clés

La logique des protocoles propres à la carte est mise en œuvre en Swift dans le module CardCore. Les primitives se répartissent ainsi : les opérations sur la courbe brainpoolP384r1 et le CMAC sont écrits dans le moyen ; l'AES en mode CBC est appelé dans CommonCrypto ; SHA-2 est appelé dans CryptoKit ; la vérification des signatures ECDSA et RSA est faite par Security.framework. Tous les algorithmes sont publiés par des organismes de normalisation internationaux ; aucun n'est propriétaire.

Algorithme	Mode	Taille de clé	Fonction
ECDH sur brainpoolP384r1	PACE-GM (mappage générique)	384 bits	Accord de clés PACE
AES	CBC	256 bits	Confidentialité de chaque APDU après PACE
AES	CMAC	256 bits	Intégrité de chaque APDU après PACE
SHA-256	s.o.	s.o.	Dérivation des clés de session PACE
SHA-224, SHA-256, SHA-384, SHA-512	s.o.	s.o.	Condensats des signatures d'authentification
ECDSA sur NIST P-384	s.o.	384 bits	Signature d'authentification client
RSA	PKCS#1 v1.5	3072 bits	Signature d'authentification client
RSA	PSS	3072 bits	Signature d'authentification client

La fonction de condensation des signatures ECDSA est choisie par le service appelant parmi SHA-224, SHA-256, SHA-384 et SHA-512 ; les cartes à clé RSA n'emploient que SHA-256. La vérification locale est faite au moyen de la clé publique de la carte avant que la signature ne soit rendue au système.

Normes correspondantes : ECDH, RFC 5639 et BSI TR-03111 ; AES, FIPS 197 avec NIST SP 800-38A (CBC) et NIST SP 800-38B avec RFC 4493 (CMAC) ; SHA-2, FIPS 180-4 ; ECDSA, FIPS 186-5 et ANSI X9.62 ; RSA, RFC 8017.

Gestion des clés

- Les clés privées sont générées dans la carte par l'autorité émettrice et n'en sortent jamais. Le moyen ne peut pas les lire et ne les détient jamais.
- Les clés de session PACE sont éphémères : dérivées par session, gardées en mémoire seulement, libérées à la fin de la session et jamais écrites sur un support persistant.
- Aucun séquestre de clés, aucun recouvrement, aucune gestion de clés à distance, aucune transmission de clé sur un réseau.

C. Cas d'un moyen de cryptologie relevant de la catégorie 3 de l'annexe 2 du décret n° 2007-663 du 2 mai 2007

Le déclarant déclare que le moyen de cryptologie relève de la catégorie 3 de l'annexe 2 du décret n° 2007-663 du 2 mai 2007. Les éléments justificatifs suivent. Il appartient à l'ANSSI d'apprécier cette qualification ; dans l'attente de son appréciation, celle-ci n'est pas présentée comme acquise.

Présentez le mode de commercialisation du moyen de cryptologie et le marché auquel il s'adresse

Distribution au grand public, sans négociation, sans personnalisation et sans contrat particulier. Le canal principal est l'App Store d'Apple ; d'autres canaux peuvent s'y ajouter, selon les mêmes modalités. Le marché visé est le porteur d'une carte nationale d'identité finlandaise souhaitant s'authentifier auprès de services en ligne. Le code source est public :

<https://github.com/ReFineID/ReFineID-Apple>

Expliquez pourquoi la fonctionnalité cryptographique du moyen ne peut pas être modifiée facilement par l'utilisateur

La suite cryptographique est fixée à la compilation. La suite PACE et les paramètres de domaine sont imposés par la carte et inscrits dans le produit ; aucune interface, aucun réglage et aucun fichier de configuration ne permet de choisir un algorithme, une longueur de clé ou un protocole différent. L'application est signée et son intégrité vérifiée par le système d'exploitation, qui refuse d'exécuter un binaire modifié.

Expliquez en quoi les modalités d'installation du moyen ne nécessitent pas d'assistance importante ultérieure de la part du fournisseur

L'installation se fait par l'App Store en une action. Il n'y a ni serveur à paramétrer, ni certificat à installer, ni abonnement à souscrire. Le porteur saisit le numéro d'accès imprimé sur sa carte, présente la carte une fois, et le moyen est opérationnel. Aucune intervention du fournisseur n'est requise.

D. Renouvellement d'autorisation de transfert ou d'exportation

Sans objet. La rubrique D ne concerne qu'un moyen ayant déjà fait l'objet d'une autorisation de transfert ou d'exportation ; la présente demande est une première déclaration et n'en invoque aucune.

E. Pièces à joindre

Les pièces, une par une :

Pièce demandée	État
Document général présentant la société	Sans objet : le déclarant est une personne physique.
Extrait K bis de moins de trois mois	Sans objet : aucune société immatriculée.
Brochure commerciale	Sans objet : le moyen est distribué sans brochure ; sa page sur l'App Store en tient lieu.
Brochure technique	Jointe : le présent dossier, rubriques B.2 et B.3.
Manuel utilisateur	Sans objet : l'usage se limite à saisir le numéro d'accès et à présenter la carte, décrit en rubrique C.
Guide administrateur	Sans objet : le moyen ne comporte aucune fonction d'administration.

Le code source complet est publiquement accessible à l'adresse indiquée en rubrique C, ce qui couvre les éléments relatifs à la conception du moyen.

F. Attestation

Champ	Valeur
Nom et prénoms	Koistinen, Petri
Agissant en qualité de	Fournisseur et auteur du moyen, personne physique
Pour le compte de	Lui-même, en son nom propre (aucune personne morale)
Date	3 août 2026

Je soussigné, Koistinen Petri, agissant en qualité de fournisseur et auteur du moyen et pour mon propre compte, certifie que les renseignements figurant dans le présent dossier et les pièces qui lui sont jointes sont exacts et ont été établis de bonne foi, et m'engage à porter à la connaissance de l'Agence nationale de la sécurité des systèmes d'information, sans délai, tout élément nouveau de fait ou de droit de nature à modifier la présente déclaration ou les éléments joints. Toute omission ou toute fausse déclaration expose le déclarant aux sanctions prévues aux articles 34 et 35 de la loi n° 2004-575 du 21 juin 2004 modifiée.

La signature de la présente attestation est la signature électronique qualifiée apposée sur ce document ; ses conditions de vérification sont rappelées en pied de page.

Ce document est signé électroniquement. La signature est une signature électronique qualifiée au sens du règlement (UE) n° 910/2014 (article 3, point 12), créée par un dispositif de création de signature électronique qualifié et fondée sur un certificat qualifié délivré par l'Agence des services de données numériques et démographiques (Digi- ja väestötietovirasto, DVV), prestataire de services de confiance qualifié finlandais. En vertu de l'article 25, paragraphe 2, du même règlement, elle a un effet juridique équivalent à celui d'une signature manuscrite.

La validation est possible en ligne et gratuitement à l'adresse <https://dvv.fineid.fi/fr/validation>, ou par tout autre moyen retenu par le destinataire.

English version

The declaration is made under chapter II, without prejudice to the application of article 30 II, which frees from every formality a means providing exclusively authentication or integrity-control functions. The declarant does not prejudge that qualification and asks ANSSI to state whether it applies to the means described below.

This document is the declaration. It is drawn up according to ANSSI's annexe I, following sections A to F in the same order, under their headings or a close equivalent: every question is answered here, in its place.

Nature of the request: **declaration of supply and of transfer from a member state of the European Union** of a means of cryptology, under chapter II of decree No 2007-663 alone.

The declarant is established in Finland and the means is distributed from within the European Union, through Apple's App Store among other channels. The operations declared are therefore the supply of the means in France and its transfer from a member state. Transfer from France to a member state, and export from France to a third state – which article 30 IV subjects to authorisation – are not performed by the declarant and are not the subject of this declaration.

No authorisation under chapter III is requested.

A. Declarant and/or applicant

The declarant is an individual. ReFineID is a trading name he uses in a personal capacity; it names no legal entity. There is no registered company name, no SIRET number, and no company on whose behalf the declaration is made.

Field	Value
Name	Koistinen, Petri
Nationality	Finnish
Address	Niittaajankatu 8a A 21, 00810 Helsinki, Finland
Telephone	+358 44 956 4098
Email	petri.koistinen@iki.fi

Technical contact for ANSSI: the same person, same details. The declarant is also the manufacturer, so the third-party manufacturer section does not apply.

B. Means of cryptology to which the declaration and/or the authorisation request applies

B.1. General information

Field	Value
Name of the means	ReFineID
Generic designation	Middleware for a national identity card
Brand	ReFineID
Commercial reference	ReFineID for Apple platforms (App Store application, bundle identifier <code>fi.refineid.ReFineID</code>)
Version	Calendar versioning YY.M.D (26.8.3 at the date of this dossier)
Date placed on the market	1 November 2026
Platforms	iOS 26, iPadOS 26, macOS 26

B.2. Functional description

B.2.1. Classification of the means

Software. The means contains no hardware component.

B.2.2. General description of the means

ReFineID makes the Finnish national identity card usable as a client certificate identity through Apple's security frameworks. It reads the card over the phone's NFC antenna or a contact smart-card reader, publishes the card's authentication certificate and public key to the system keychain through CryptoTokenKit, and passes signature requests to the card. Safari and other system consumers then authenticate with the card as they would with any other client certificate. The holder uses it to sign in to online services with their identity card.

This declaration covers that Apple-platform application alone, distributed through the App Store. A ReFineID middleware for desktop systems, distributed separately and with different cryptographic functions, falls outside its scope.

B.2.3. Category of the principal function

Information security (cryptographic library and middleware). None of the other categories offered – computer, sending/storage/reception of information, network – applies.

B.3. Technical description

B.3.1. Description of the cryptographic functionality

Two functions, and nothing else:

1. **Opening a secure channel to the card.** The card seals its PKCS#15 application on the contactless interface and refuses every read until PACE has run. PACE is a password-authenticated key agreement keyed by the card access number printed on the card. It authenticates knowledge of the access number and derives session keys; every exchange with the card afterwards is encrypted and authenticated under them.

2. **Client authentication signatures.** The private key stays in the card, which performs the signature. The means formats the input, passes it to the card, and verifies the result against the card's own public key before returning it to the operating system.

The encryption is confined to that channel and to the contactless interface alone. It is not offered to the holder: it is imposed by the card's access policy. On the contact interface the means encrypts nothing. The key published to the operating system is reserved for signature: the means offers its callers neither decryption nor key agreement.

The means does not encrypt user data at rest, does not encrypt files or storage, provides no encrypted messaging or telephony, implements no VPN or transport tunnel, and performs no network communication of its own.

B.3.2. Categories the cryptographic functions fall under

Authentication, integrity, confidentiality and signature – all four, exercised between the means and the card, not on the user's data.

B.3.3. Secure protocols used by the means

Neither IPsec, SSH, VoIP protocols, nor SSL/TLS. TLS is handled by the operating system; the means implements no TLS stack and contributes only the card's signature.

Other protocols: PACE as specified in ICAO Doc 9303 Part 11 and BSI TR-03110-3, suite id-PACE-ECDH-GM-AES-CBC-CMAC-256 (OID 0.4.0.127.0.7.2.2.4.2.4); Secure Messaging as specified in ISO/IEC 7816-4.

B.3.4. Cryptographic algorithms used and their maximum key lengths

The card's own protocol logic is implemented in Swift in the CardCore module. The primitives divide as follows: the brainpoolP384r1 curve operations and the CMAC are written in the means; AES in CBC mode is called in CommonCrypto; SHA-2 is called in CryptoKit; ECDSA and RSA signature verification is done by Security.framework. All algorithms are published by international standards bodies; none is proprietary.

Algorithm	Mode	Key size	Function
ECDH on brainpoolP384r1	PACE-GM (generic mapping)	384 bits	PACE key agreement
AES	CBC	256 bits	Confidentiality of each APDU after PACE
AES	CMAC	256 bits	Integrity of each APDU after PACE
SHA-256	n/a	n/a	Derivation of the PACE session keys
SHA-224, SHA-256, SHA-384, SHA-512	n/a	n/a	Digests of the authentication signatures
ECDSA on NIST P-384	n/a	384 bits	Signed by the card, verified locally
RSA	PKCS#1 v1.5	3072 bits	Signed by the card, verified locally
RSA	PSS	3072 bits	Signed by the card, verified locally

The digest for an ECDSA signature is chosen by the calling service from SHA-224, SHA-256, SHA-384 and SHA-512; RSA card generations use SHA-256 alone. Local verification is against the card's own public key, before the signature is returned to the system.

Corresponding standards: ECDH, RFC 5639 and BSI TR-03111; AES, FIPS 197 with NIST SP 800-38A (CBC) and NIST SP 800-38B with RFC 4493 (CMAC); SHA-2, FIPS 180-4; ECDSA, FIPS 186-5 and ANSI X9.62; RSA, RFC 8017.

Key management

- The card's private keys are generated on the card by the issuing authority and never leave it. The means cannot read them and never holds them.
- PACE session keys are ephemeral: derived per session, held in memory only, released when the session ends and never written to persistent storage.
- There is no key escrow, no key recovery, no remote key management, and no transmission of any key over a network.

C. Case of a means of cryptology falling within category 3 of annex 2 to decree No 2007-663 of 2 May 2007

The declarant declares that the means of cryptology falls within category 3 of annex 2 to decree No 2007-663 of 2 May 2007. The supporting points follow. It is for ANSSI to assess that qualification; until it has, the qualification is not presented as held.

Present the means of commercialisation and the market it addresses

Distributed to the general public, with no negotiation, no customisation and no individual contract. The principal channel is the Apple App Store; other channels may be added, on the same terms. The target market is the holder of a Finnish national identity card wishing to authenticate to online services. The source code is public:

<https://github.com/ReFineID/ReFineID-Apple>

Explain why the cryptographic functionality cannot easily be modified by the user

The cryptographic suite is fixed at compile time. The PACE suite and domain parameters are imposed by the card and written into the product; no interface, setting or configuration file allows a different algorithm, key length or protocol to be chosen. The application is signed and its integrity verified by the operating system, which refuses to run a modified binary.

Explain how installation requires no significant subsequent support from the supplier

Installation is a single action through the App Store. There is no server to configure, no certificate to install and no service to subscribe to. The holder enters the access number printed on their card, presents the card once, and the means is operational. No supplier intervention is required.

D. Renewal of a transfer or export authorisation

Not applicable. Section D concerns a means for which a transfer or export authorisation was previously granted; this is a first declaration and invokes none.

E. Documents to attach

The items, one by one:

Item requested	Status
General document presenting the company	Not applicable: the declarant is a private individual.
Extract K bis less than three months old	Not applicable: no registered company.
Commercial brochure	Not applicable: the means is distributed without one; its public listing serves instead.
Technical brochure	Attached: this dossier, sections B.2 and B.3.
User manual	Not applicable: use is limited to entering the access number and presenting the card, described in section C.
Administrator guide	Not applicable: the means has no administration function.

The complete source code is publicly accessible at the address given in section C, which covers the design elements.

F. Attestation

Field	Value
Name	Koistinen, Petri
Acting in the capacity of	Supplier and author of the means, private individual
On behalf of	Himself, in his own name (no legal entity)
Date	3 August 2026

I, the undersigned, Koistinen Petri, acting as supplier and author of the means and on my own behalf, certify that the information in this dossier and in the documents attached to it is accurate and has been established in good faith, and undertake to inform the Agence nationale de la sécurité des systèmes d'information without delay of any new matter of fact or of law liable to alter this declaration or the attached material. Any omission or false declaration exposes the declarant to the penalties provided for in articles 34 and 35 of law No 2004-575 of 21 June 2004 as amended.

The signature on this attestation is the qualified electronic signature applied to this document; how to verify it is set out in the footer.

This document is electronically signed. The signature is a qualified electronic signature within the meaning of Regulation (EU) No 910/2014 (Article 3(12)), created by a qualified electronic signature creation device and based on a qualified certificate issued by the Digital and Population Data Services Agency (DVV), a Finnish qualified trust service provider. Under Article 25(2) of that Regulation it has legal effect equivalent to that of a handwritten signature.

Validation is available online, free of charge, at <https://dvv.fineid.fi/en/validation>, or by any other means the recipient prefers.